

Reporte de Triage Técnico: SecureWallet

Durante la revisión del sistema SecureWallet se identificaron varios aspectos que pueden afectar la seguridad y el correcto funcionamiento de la aplicación.

1. Condición de carrera en las transferencias

Ubicación: Línea 63 (`time.sleep(0.5)`)

Problema encontrado:

El sistema no tiene un mecanismo que controle que varias transferencias se ejecuten al mismo tiempo. Si dos solicitudes llegan casi simultáneamente, ambas pueden consultar el mismo saldo antes de que se actualice la información.

Impacto:

Esto puede ocasionar que se aprueben dos transferencias utilizando el mismo dinero disponible, generando inconsistencias en los saldos e incluso permitiendo que una cuenta quede con un saldo incorrecto.

Posible solución:

Implementar un mecanismo de bloqueo o control de concurrencia para que solo una transferencia pueda modificar el saldo de una cuenta a la vez.

2. Falta de validación de la cuenta destino

Ubicación: Líneas 61 y 62 (`if db[origin]["estado"] == "ACTIVA":`)

Problema encontrado:

El sistema valida únicamente que la cuenta de origen esté activa, pero no verifica el estado de la cuenta que recibe la transferencia.

Impacto:

Actualmente es posible enviar dinero a cuentas bloqueadas, lo que puede incumplir las reglas de negocio y generar problemas en el control de las operaciones.

Posible solución:

Antes de realizar la transferencia, validar que tanto la cuenta de origen como la cuenta de destino se encuentren en estado activo.

3. Falta de validación del monto de transferencia

Ubicación: Línea 59 (`amount = payload.get("monto")`)

Problema encontrado:

El sistema recibe el valor del monto sin verificar si es un número válido o si es mayor que cero.

Impacto:

Un usuario podría enviar valores negativos y alterar el resultado de la operación, generando movimientos financieros incorrectos y afectando la integridad de los datos.

Posible solución:

Validar que el monto sea numérico y que sea mayor a cero antes de procesar cualquier transferencia.

4. Endpoint administrativo sin protección

Ubicación: Línea 78 (elif path == "/api/v1/accounts/admin/bypass-status":)

Problema encontrado:

Existe una ruta administrativa que permite cambiar el estado de las cuentas, pero no tiene ningún mecanismo de autenticación o autorización.

Impacto:

Cualquier persona que descubra la ruta podría activar o bloquear cuentas sin contar con permisos de administrador, representando un riesgo importante para la seguridad del sistema.

Posible solución:

Implementar autenticación mediante tokens, API Keys o validación de roles para restringir el acceso únicamente a usuarios autorizados.

5. Exceso de responsabilidades en una sola clase

Ubicación: Clase PaymentGatewayAPI

Problema encontrado:

La misma clase se encarga de recibir las solicitudes HTTP, validar datos, ejecutar las reglas de negocio y manipular directamente los archivos de almacenamiento.

Impacto:

Esta estructura dificulta el mantenimiento, las pruebas y futuras mejoras del sistema, ya que cualquier cambio puede afectar varias funcionalidades al mismo tiempo.

Posible solución:

Separar las responsabilidades en diferentes clases o módulos, permitiendo que cada componente tenga una única función dentro de la aplicación.